

Cartographie des risques

TD Séance 1 — Sécurité & Coûts dans le Cloud — Master IA, 2iE

Groupe : _____ Domaine : _____ Date : _____

Consignes (5 min de lecture)

Pour chaque risque identifié, remplissez une ligne du tableau.

Colonne	Comment l'évaluer
Risque	Une phrase précise. Pas « piratage » mais « Fuite de la clé API OpenAI dans un commit ».
Catégorie	Une seule parmi : Secrets, Données, Config cloud, Application, IA / modèle, Coûts, Réseau, Conformité.
P (1-5)	Probabilité : 1 très rare, 5 quasi-certain.
I (1-5)	Impact : 1 négligeable, 5 catastrophique.
Score	$P \times I$. Un risque à 20 est critique, à 4 mineur.
Mesure	Action concrète et vérifiable. Pas « faire attention » mais « Trufflehog en CI bloquant ».

Objectif : au moins **8 lignes** couvrant au moins **6 catégories** sur les 8 listées.

Échelles de référence

Probabilité (P)

N	Sens / exemple
1	Très rare (APT ciblée)
2	Rare (vol identité dev)
3	Plausible (erreur en CI)
4	Fréquent (commit de secret)
5	Quasi-certain (repo public scanné)

Impact (I)

N	Sens / exemple
1	Négligeable (log verbeux)
2	Gêne mineure (indispo 5 min)
3	Incident à gérer (test data)
4	Sérieux (200 \$ AWS)
5	Catastrophique (fuite RGPD)

Votre tableau — à remplir

#	Risque	Catégorie	P	I	Score	Mesure
1						
2						
3						
4						
5						
6						
7						
8						
9						
10						

Catégories couvertes (cocher au fur et à mesure) :

☐ Secrets
☐ IA / modèle

☐ Données
☐ Coûts

☐ Config cloud
☐ Réseau

☐ Application
☐ Conformité

Exemple complet — Scoring crédit microfinance

À titre de référence uniquement. Adaptez à **votre** domaine, ne recopiez pas.

#	Risque	Cat.	P	I	Sc.	Mesure
1	Clé API du provider exposée dans un commit	Secrets	4	5	20	.env + trufflehog CI
2	Accès non autorisé aux données clients	Données	3	5	15	IAM rôles + audit log
3	Bucket S3 du modèle exposé public	Config cloud	3	4	12	Block public access
4	Injection SQL via formulaire client	Application	2	5	10	ORM SQLAlchemy + Pydantic
5	Biais discriminatoire du modèle (ethnie, genre)	IA / modèle	3	4	12	Audit fairness régulier
6	Instance EC2 oubliée allumée le week-end	Coûts	3	4	12	Alerte budget AWS à 80 %
7	DDoS sur l'API de scoring	Réseau	2	4	8	Rate limiting + Cloudflare
8	Model stealing par requêtes massives	IA / modèle	2	3	6	Rate limit + monitoring
9	Conservation données > 1 an sans consentement	Conformité	3	5	15	Rétention 12 mois max
10	Modèle déployé avec accuracy < 70 %	IA / modèle	2	4	8	CI bloque si test < 80 %

Et après ? Comment réutiliser cette cartographie

- **Top 3 par score** = ce que vous traitez en priorité dans le Livrable 1, section « Plan de mise en œuvre ».
- **Catégorie Coûts** = base de votre section budget du Livrable 1.
- **Catégorie Conformité** = base de votre section RGPD du Livrable 1.
- **Catégorie IA / modèle** = ce qui différencie votre projet d'une app web classique. **Ne pas l'oublier.**

Évaluation de cette section

Critère	Points
Au moins 8 risques	8
Au moins 6 catégories couvertes	6
Risques spécifiques au projet (pas « piratage »)	5
Cohérence des scores $P \times I$	3
Mesures concrètes et vérifiables	3
Total section « Analyse de risques » du Livrable 1	25 / 100